RAPPORT TP 4 – Scan et analyse de sécurité d'un système Windows

---

1. Introduction

Ce TP avait pour objectif d'analyser une machine **Windows** comme le ferait un attaquant ou un auditeur de sécurité.
L'objectif principal était de répondre à la question :
Quels services un système Windows expose-t-il sur le réseau et quels sont les risques associés ?

Ce travail est essentiel car :

- Windows est omniprésent en entreprise.
- De nombreuses attaques ciblent ses services (SMB, RDP, NetBIOS).
- Une mauvaise configuration peut exposer toute une infrastructure.

---

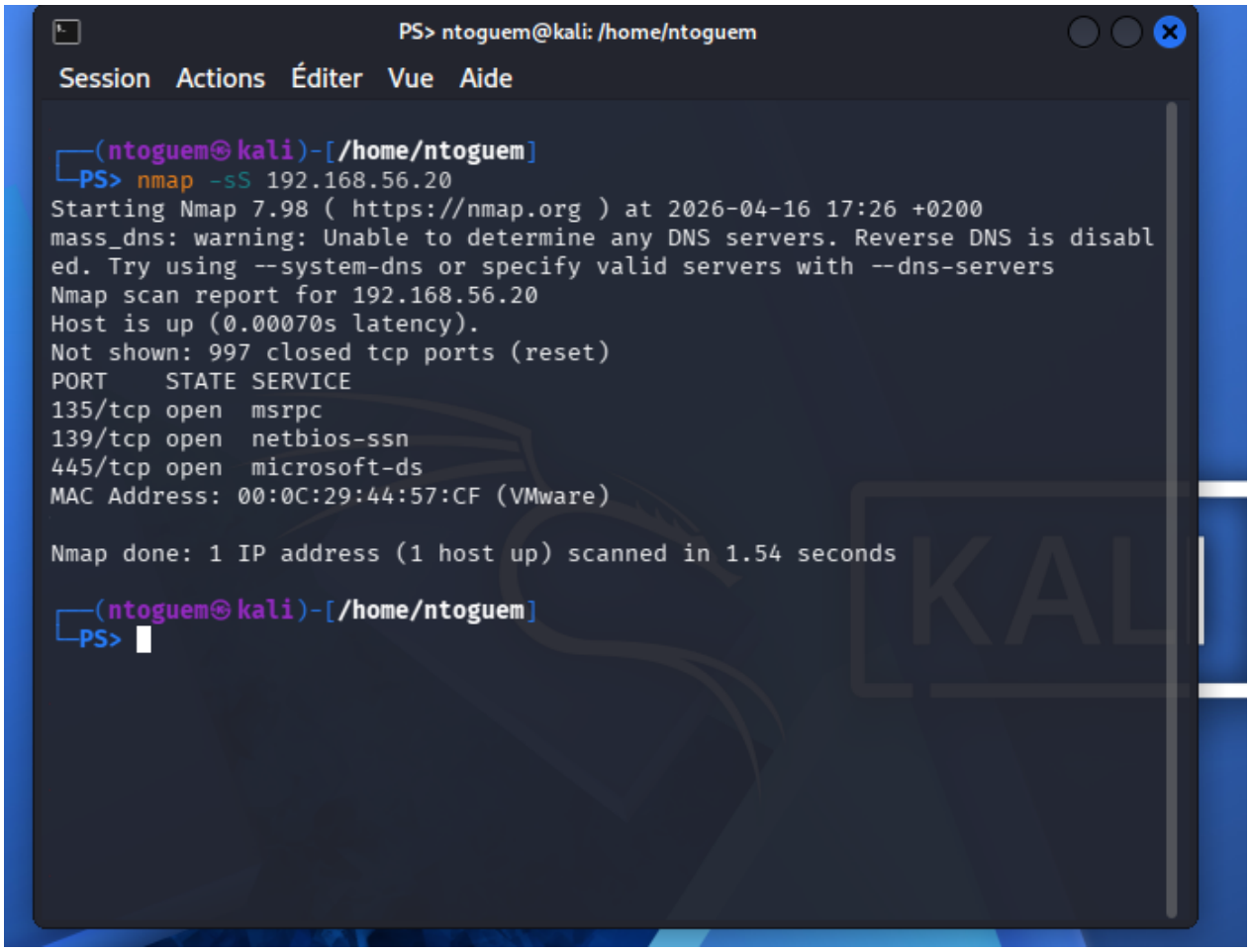
2. Scan des ports Windows

Commande utilisée :
```
nmap -sS 192.168.56.20
```

Ce que j'ai retenu :

- Le scan SYN permet d'identifier les ports ouverts sans établir de connexion complète.
- Les ports détectés (135, 139, 445, 3389) correspondent à des services critiques.
- Ces services sont souvent ciblés par des attaques comme **WannaCry**.

Résultat observé :
Capture d'écran du scan Nmap montrant les ports ouverts sur la machine Windows.



Interprétation :

- Port 445 → Service SMB (partage de fichiers).
- Port 3389 → Service RDP (accès distant).
  Ces services doivent être surveillés et sécurisés.

---

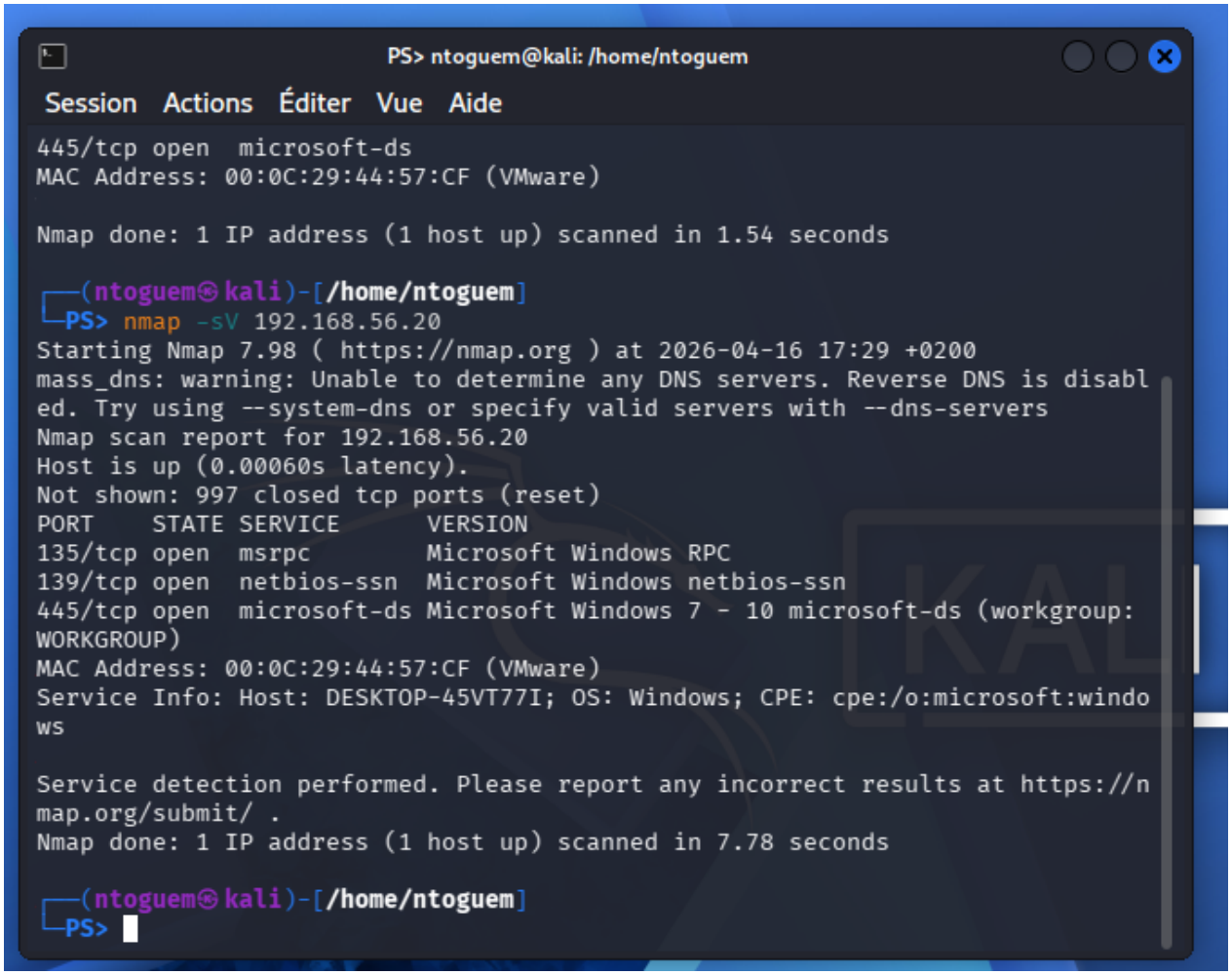
3. Identification des services Windows

Commande utilisée :
`nmap -sV 192.168.56.20`

Ce que j'ai retenu :

- L'option **-sV** permet d'identifier la version exacte des services actifs.
- Cela aide à savoir si un service est obsolète ou vulnérable.
- Les scripts Nmap spécialisés pour Windows (ex. `smb-os-discovery`) permettent d'obtenir des informations précises sur le système.

Résultat observé :
Capture d'écran du résultat Nmap avec les versions des services détectés.



Interprétation :

- Permet de connaître la version du système et des services exposés.
- Ces informations sont précieuses pour un attaquant qui cherche une faille connue.

---

4. Analyse du service SMB avec smb-os-discovery

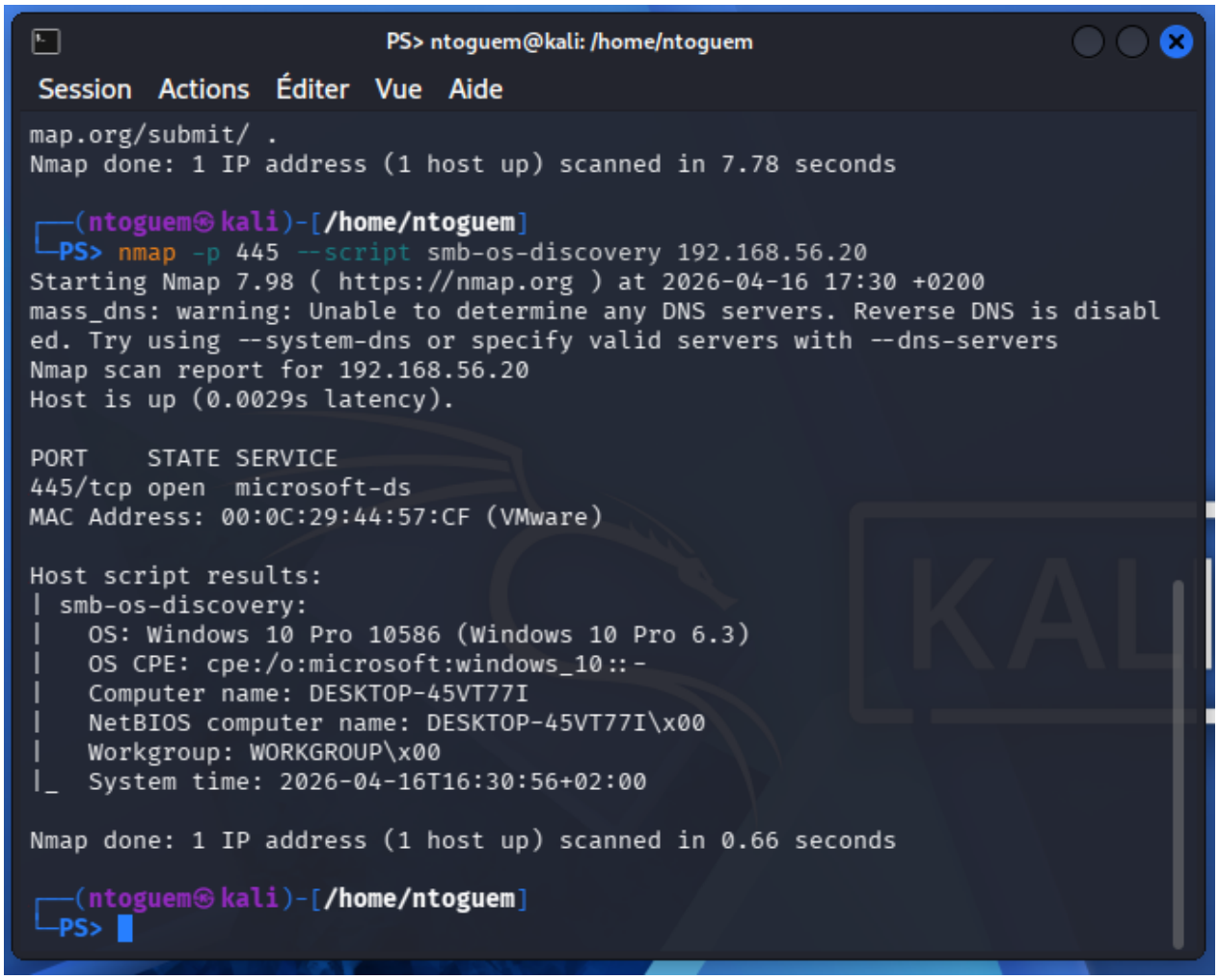
Commande utilisée : `nmap -p 445 --script smb-os-discovery 192.168.56.20`

Ce que j'ai retenu :

- Ce script est spécialisé pour analyser le protocole **SMB** sur Windows.

- Il permet de récupérer des informations détaillées sur le système, comme :
  - le nom de la machine,
  - le domaine ou groupe de travail,
  - la version du système d'exploitation,
  - la version du service SMB.
- Ces informations sont précieuses pour un attaquant car elles permettent d'adapter les attaques en fonction de la configuration détectée.

Résultat observé : Capture d'écran du résultat du script smb-os-discovery montrant les détails du système Windows.



5. Détection de vulnérabilités SMB

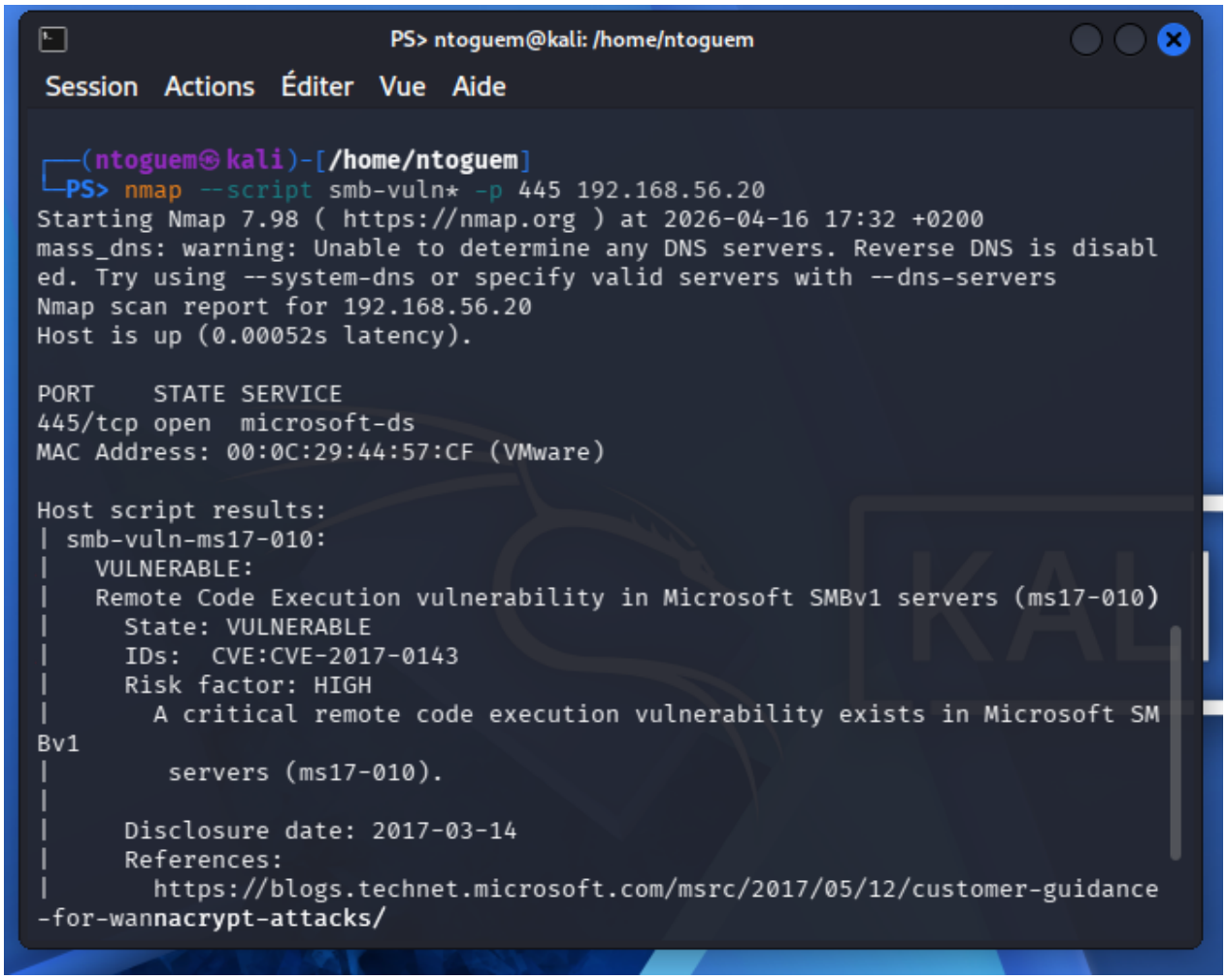
Commande utilisée : `nmap -p 445 --script smb-vuln* 192.168.56.20`

Ce que j'ai retenu :

- Les scripts **smb-vuln*** testent les vulnérabilités connues du protocole SMB.

- Ils permettent de détecter des failles critiques pouvant mener à une exécution de code à distance.
- Ces vulnérabilités ont déjà été exploitées dans des attaques majeures comme **WannaCry**.

Résultat observé : Capture d'écran du résultat du script SMB.



6. Analyse du service RDP (si activé)

Commande utilisée :

```
nmap -p 3389 --script rdp-enum-encryption 192.168.56.20
```

Ce que j'ai retenu :

- Ce script permet d'analyser la configuration du protocole RDP.
- Il révèle le type de chiffrement utilisé et les paramètres de sécurité.
- Ces informations peuvent aider à évaluer la robustesse du service.

Résultat observé :
Capture d'écran du résultat du script RDP.

```
PS> ntoguem@kali: /home/ntoguem
Session  Actions  Éditer  Vue  Aide
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|_      https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|_smb-vuln-ms10-061: NT_STATUS_ACCESS_DENIED
|_smb-vuln-ms10-054: false

Nmap done: 1 IP address (1 host up) scanned in 5.26 seconds

┌──(ntoguem㉿kali)-[/home/ntoguem]
└─PS> nmap -p 3389 --scriipt rdp-enum-encryption 192.168.56.20
/usr/lib/nmap/nmap: unrecognized option '--scriipt'
See the output of nmap -h for a summary of options.

┌──(ntoguem㉿kali)-[/home/ntoguem]
└─PS> nmap -p 3389 --script rdp-enum-encryption 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-16 17:35 +0200
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabl
ed. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.20
Host is up (0.0051s latency).

PORT     STATE  SERVICE
3389/tcp closed ms-wbt-server
MAC Address: 00:0C:29:44:57:CF (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.27 seconds

┌──(ntoguem㉿kali)-[/home/ntoguem]
└─PS>
```

---

6. Analyse évolutive de la sécurité

Ce que j'ai retenu :

- Cette étape permet de prendre du recul sur l'ensemble des résultats.
- Les faiblesses critiques identifiées concernent principalement SMB et RDP.
- Les mesures de sécurisation recommandées sont :
  - Désactiver SMBv1.
  - Limiter l'accès RDP aux administrateurs.
  - Activer le pare-feu Windows.
  - Mettre en place des zones de confiance réseau.

Résultat observé :
Capture d'écran du pare-feu ou des paramètres de sécurité appliqués.

---

7. Analyse globale de sécurité

Ce que j'ai retenu :

- Les services exposés augmentent la surface d'attaque.
- Le service le plus dangereux est SMB, car il permet un accès direct aux fichiers.
- Les actions recommandées :
  - Mettre à jour le système.
  - Restreindre les accès réseau.
  - Activer les protections IDS/IPS.

---

8. Lien avec l'entreprise

Ce que j'ai retenu :

- Un SOC utilise ce type d'analyse pour détecter les failles avant qu'elles ne soient exploitées.
- La surveillance des services Windows est essentielle pour prévenir les attaques internes et externes.
- La Threat Intelligence permet d'anticiper les vulnérabilités connues et de renforcer la sécurité.

---

9. Conclusion

Ce TP m'a permis de :

- Comprendre comment un attaquant analyse un système Windows.
- Identifier les services critiques et leurs vulnérabilités.
- Appliquer des mesures de sécurisation adaptées.
- Développer une approche proactive de la sécurité réseau.

Difficultés rencontrées :

- Exécution des scripts Nmap nécessitant des privilèges administrateur.
- Interprétation des résultats SMB.

Limites de l'analyse :

- Les scripts Nmap ne détectent pas toutes les vulnérabilités.
- Certains services peuvent être masqués par le pare-feu.